CASE STUDY

The Cl0p MOVEit Breach and the File-Transfer Extortion Playbook: A 2023 Case Study

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

Over the US Memorial Day weekend of 2023, the Cl0p extortion group exploited a zero-day flaw in Progress MOVEit Transfer, a managed file transfer product used by thousands of organizations to move sensitive data between parties. The flaw, CVE-2023-34362, was a SQL injection weakness that let an unauthenticated attacker reach the application database and drop a web shell that stole files wholesale. Cl0p did not encrypt anything. It copied the data, listed victims on its leak site, and demanded payment to keep the files unpublished. By August 2024 the running tally reached roughly 2,773 organizations and about 95.8 million individuals, and it is best read as a floor, because many of the organizations hit were service providers whose own customers became downstream victims.

MOVEit was not a one-off. It was the fourth and largest in a pattern: Cl0p had already run the same exploit-exfiltrate-extort play against Accellion FTA in 2020 and 2021, Fortra GoAnywhere in early 2023, and would run it again against Cleo file-transfer software in late 2024. The through-line is the target class. Managed file transfer software sits on the internet edge, concentrates other organizations' most sensitive data, and is bought by teams who treat it as plumbing rather than as a high-value attack surface. For a vulnerability management program, the lesson is that an internet-facing application that aggregates third-party data is a crown-jewel asset whose unauthenticated critical flaws are ransomware-grade events, whether or not a single file is ever encrypted.

> Evidence grade: **Confirmed** overall (Progress, CISA, FBI and Microsoft for the vulnerabilities and attribution; victim-count totals are **Reported** tallies marked below).

Key facts at a glance

Field	Value
Lead vulnerability	CVE-2023-34362, SQL injection in MOVEit Transfer, CVSS 9.8, unauthenticated remote
Related MOVEit flaws	CVE-2023-35036 and CVE-2023-35708, found in the hardening review and fixed in June 2023
Post-exploitation	`human2.aspx` web shell (LEMURLOOT family): file theft plus Azure Storage key harvest
Extortion model	Data theft only, no encryption; leak-site naming and a payment deadline
Actor	Cl0p, also tracked as TA505, FIN11, LACE Tempest and Graceful Spider
First exploitation	Observed from around 27 May 2023, before the 31 May advisory
Scale	About 2,773 organizations and about 95.8 million individuals (Emsisoft tally, August 2024, a floor)
The pattern	Fourth MFT campaign: Accellion FTA (2020 to 2021), GoAnywhere (2023), MOVEit (2023), Cleo (2024)

Key findings

- **A single unauthenticated SQL injection caused a global data breach.** CVE-2023-34362 (CVSS 9.8) let an attacker inject SQL into the MOVEit Transfer web application without credentials, read and alter the database, and install a web shell. Two further SQL injection flaws, CVE-2023-35036 and CVE-2023-35708, were found during the code review that followed and were patched in June 2023.
- **The payload was theft, not encryption.** Post-exploitation deployed a web shell commonly named `human2.aspx` (the LEMURLOOT family) that enumerated and exfiltrated stored files and could harvest the service account's cloud storage keys. Cl0p's extortion rested entirely on the stolen copies, so there was no encryption event for a backup to recover from.
- **Mass exploitation preceded disclosure.** Exploitation was observed from around 27 May 2023, days before Progress published its advisory on 31 May 2023, which is the defining feature of a zero-day: there was no patch window to be inside of.
- **The damage spread through third parties.** Many organizations were breached not through their own MOVEit server but through a vendor's, for example the payroll provider Zellis, so one compromised server exposed many unrelated downstream organizations. This is why the individual count dwarfs the organization count.
- **It was a repeat of a proven playbook.** Cl0p (also tracked as TA505, FIN11 and LACE Tempest) ran the identical exploit-steal-extort pattern against Accellion FTA (CVE-2021-27101 and related, 2020 to 2021), Fortra GoAnywhere MFT (CVE-2023-0669, early 2023, about 130 organizations claimed), and Cleo Harmony, VLTrader and LexiCom (CVE-2024-50623 and CVE-2024-55956, late 2024, about 200 victims claimed). The target class, not the specific product, is the constant.

Top recommendations

1. Inventory every managed file transfer and edge data-exchange product, including ones a vendor operates on your behalf, and treat them as crown-jewel internet-facing assets on the shortest patch clock, not as background infrastructure.
2. Plan for the zero-day case, because the MOVEit and Cleo flaws were exploited before a patch existed. Put these products behind authenticated access or a VPN, restrict outbound connections, monitor for web shells and anomalous file access, and be ready to take the service offline.
3. Treat an unauthenticated critical flaw in a data-aggregating edge product as a ransomware-grade exposure during prioritization, even with no encryption behavior, because pure data-theft extortion causes the same business harm.
4. Map third-party and fourth-party exposure: know which of your vendors run these products with your data, because a breach of their server is a breach of you, and your incident response may depend on their disclosure timeline.
5. Minimize data at rest in transfer systems. A file that was deleted after delivery, or never staged on an internet-facing box, cannot be stolen from one.

Scope and method

This study covers the Cl0p MOVEit campaign of 2023 as its center, with the surrounding Accellion, GoAnywhere and Cleo campaigns as context for the pattern. Sources are Progress, Fortra, Cleo, CISA, the FBI and vendor and victim reporting. Each claim carries one of three evidence grades.

Grade	Meaning
Confirmed	The vendor, CISA or the FBI confirms the vulnerability or the exploitation
Reported	A single vendor, tracker or press account, not independently corroborated
Demonstrated	A research reproduction with no known in-the-wild use at the time

Part 1: the playbook, four times

Cl0p's file-transfer campaigns are best understood as one method applied to one target class across four years. The method is always the same four moves: find or buy a zero-day in an internet-facing file-transfer product, fire it at scale in a short burst before defenders can react, exfiltrate the stored data, and extort by threatening to publish. What changes each time is only the product (**Confirmed** for each vulnerability and for Cl0p's involvement).

Accellion File Transfer Appliance (2020 to 2021)

The origin of the pattern. Accellion's FTA was a legacy, end-of-life file-transfer appliance. A chain of flaws in it, including CVE-2021-27101 (SQL injection) together with command-injection and server-side request forgery flaws (CVE-2021-27102, CVE-2021-27103, CVE-2021-27104), let attackers deploy the DEWMODE web shell and steal files, after which Cl0p extorted the victims. That an unsupported appliance was still holding live data on the internet edge is itself the first lesson of the whole series.

Fortra GoAnywhere MFT (early 2023)

CVE-2023-0669, a pre-authentication flaw in the License Response Servlet of the GoAnywhere administrative console, caused by insecure deserialization, gave remote code execution. Cl0p claimed on the order of 130 organizations on its leak site. This campaign, months before MOVEit, showed the group had settled on managed file transfer as a repeatable target and was willing to spend zero-days on it.

Progress MOVEit Transfer (May to June 2023)

CVE-2023-34362, the subject of Parts 2 and 3, and the largest of the four by a wide margin.

Cleo Harmony, VLTrader and LexiCom (late 2024)

CVE-2024-50623, an unrestricted file upload and download flaw, was followed by CVE-2024-55956, which Rapid7 assessed as a distinct unauthenticated command-execution flaw in the Autorun feature rather than a bypass of the first. CISA added the activity to its Known Exploited Vulnerabilities catalog, and Cl0p confirmed to reporters that it was behind the exploitation. About 200 victims were listed. The Cleo round proved the playbook still worked eighteen months after MOVEit, against a different vendor, with the same model.

Four products, four vendors, one method. The attacker did not need a new idea each time, only a new unpatched file-transfer product exposed to the internet.

Part 2: the MOVEit zero-day

MOVEit Transfer is a product organizations run to exchange files securely with partners, often as the automated backbone of payroll, benefits, healthcare and financial data flows. That is exactly what made it valuable to steal from: the data an organization most needs to move securely is the data an attacker most wants.

The vulnerability

CVE-2023-34362 is a SQL injection vulnerability in the MOVEit Transfer web application (**Confirmed**: Progress, CVSS 9.8). An unauthenticated attacker sends crafted input that the application passes into a database query, which lets the attacker read and modify the contents of the MOVEit database and, in the observed attacks, stage a web shell on the server. The attack typically lands as a crafted request to the MOVEit web front end. Progress published its advisory and an emergency patch on 31 May 2023. During the hardening review that followed, two more SQL injection flaws were identified and fixed in June 2023 (**Confirmed**):

- **CVE-2023-35036**: additional SQL injection in MOVEit Transfer.
- **CVE-2023-35708**: a SQL injection and privilege-escalation flaw addressed in a follow-up fix.

That two more injection flaws surfaced the moment anyone looked hard is its own signal: the web application had a class problem, not a single defect, which is why patching one build and moving on was never going to be enough.

The payload

The post-exploitation payload is what turned a web vulnerability into a mass breach. Attackers installed a web shell, most often a file named `human2.aspx` and tracked as the LEMURLOOT family, that let them list the files held in MOVEit, pull them out, and in cloud-backed deployments retrieve the Azure Storage account keys the service used (**Confirmed**: CISA and FBI advisory AA23-158A, and multiple vendors). The web shell masqueraded as a legitimate MOVEit component and checked for a hardcoded header before acting, which helped it blend in. The attacker's goal was the stored data, and the web shell was the pipe that drained it.

Theft, not encryption

Cl0p did not deploy encrypting ransomware here. Starting around 14 June 2023 it published victim names on its leak site and told organizations to make contact before a deadline or see their files released (**Confirmed**). That choice matters for defenders, and it is worth being precise about why:

- There was no encryption event, so no ransom note appeared on every host and no service went down in a way that triggers an obvious incident.
- There was no clean backup that could undo the harm, because the harm was that the data had already left.
- Detection had to come from the exploitation and exfiltration itself, during the short window of the attack, not from a later and louder encryption stage.

A data-theft-only model is quieter going in and just as damaging coming out, and it is increasingly the default for financially motivated groups because it sidesteps the one control, reliable backups, that most blunts classic ransomware.

MOVEit timeline

Date (2023)	Event
Around 27 May	Mass exploitation of CVE-2023-34362 begins, over the US Memorial Day weekend
31 May	Progress publishes its advisory and emergency patch
Early June	CISA and the FBI publish advisory AA23-158A; CVE added to the KEV catalog
Throughout June	Progress fixes CVE-2023-35036 and CVE-2023-35708 from the hardening review
From 14 June	Cl0p begins naming victims on its leak site with payment deadlines
June 2023 onward	Downstream victims disclose for more than a year as the count climbs

MOVEit remediation and detection

Step	What to do
Patch	Apply the Progress fixes for CVE-2023-34362, CVE-2023-35036 and CVE-2023-35708 and stay current with later MOVEit advisories; confirm every instance, including any a vendor runs for you
Hunt	Search for `human2.aspx` and other unexpected `.aspx` files in the MOVEit `wwwroot` path, review MOVEit and IIS logs for anomalous activity around late May 2023, and look for new or unexpected administrator accounts and large outbound transfers
Rotate	If exploitation is suspected, rotate the MOVEit service credentials and any Azure Storage or other cloud keys the server held, because the web shell could read them
Reduce exposure	Put MOVEit behind authenticated access or a VPN, restrict its inbound and outbound connectivity, and be prepared to take it offline during an active campaign
Assume breach	If the server was internet-facing and unpatched over the exploitation window, treat the data it held as stolen and begin breach notification analysis, do not wait for a ransom note

Remediation across the managed-file-transfer products

Because the campaign recurred against product after product, the remediation is best expressed per product and then as the platform controls that apply to any of them (**Confirmed**: each vendor's advisory):

Product	How to remediate
MOVEit Transfer	Patch to the fixed build for CVE-2023-34362, CVE-2023-35036 and CVE-2023-35708 and stay current with later advisories; hunt for `human2.aspx` in the `wwwroot` path; if exposed, rotate the service account and any Azure Storage keys and restart IIS
Fortra GoAnywhere MFT	Apply the Fortra fix for CVE-2023-0669; take the administrative console off the public internet; rotate credentials and review admin accounts
Cleo Harmony, VLTrader, LexiCom	Patch CVE-2024-50623 and CVE-2024-55956; clear and restrict the Autorun directory the exploit abused; remove internet exposure and review for dropped files
Accellion FTA	It is end-of-life: decommission it and migrate to a supported platform rather than patching, which is the lesson of its 2020 to 2021 compromise

Product	How to remediate
Any MFT product	Inventory every instance including vendor-run ones, put it behind authenticated access or a VPN, restrict inbound and outbound connectivity, minimize files left at rest, monitor for web shells and bulk egress, and keep a rehearsed take-offline option

Platform and technology controls

Layer	Remediation and mitigation
Windows / IIS host (MOVEit and other .NET MFTs)	Keep an EDR agent and AMSI enabled, run the app pool as a least-privileged identity, restart IIS after key or credential rotation, and watch for `w3wp.exe` spawning shells
Cloud storage keys (Azure Blob, Amazon S3)	If the transfer server held storage keys, rotate them on suspicion, because the web shell could read them; prefer short-lived managed identities over long-lived keys
Network and edge	Place the MFT behind a WAF and authenticated access or a VPN, filter egress so a web shell cannot exfiltrate freely, and alert on large outbound transfers
Third-party and vendor-run instances	Ask each vendor that runs an MFT with your data for its patch status and breach attestation, because their server holding your files is your exposure
Data lifecycle	Delete transferred files promptly after delivery and set retention limits, so a compromise of the staging point does not expose months of data

Part 3: who did it, and the scale

The actor

The campaigns were run by Cl0p, a financially motivated group also tracked as TA505, FIN11, LACE Tempest (Microsoft) and Graceful Spider, and known for large-scale extortion rather than quiet espionage (**Confirmed**: Microsoft and CISA). The group's distinguishing trait across these campaigns was patience in the target choice: it repeatedly found or acquired file-transfer zero-days, stockpiled them, and then fired them at internet scale in a short burst to beat the patch cycle. The MOVEit burst over a holiday weekend was deliberate timing against thinly staffed defenders.

The scale

The scale of MOVEit specifically grew for more than a year as downstream victims filed notifications (**Reported** except where noted):

- By mid-2023, early tallies already reached roughly 1,000 organizations and about 60 million individuals.

- By August 2024, the most-cited running tally stood at about 2,773 organizations and roughly 95.8 million individuals, and the trackers that maintain it caution that the figure is a floor, since several victims were service providers whose own customers were affected.
- Victims spanned government, education, finance, healthcare, insurance and large enterprises across several continents.
- Many organizations were breached through a third party's MOVEit server rather than their own, most visibly through the payroll provider Zellis, whose compromise exposed a set of unrelated large employers downstream of it.

The spread through third parties is the part a vulnerability management program must internalize. The number of organizations that ran MOVEit was a fraction of the number of organizations whose data was in a MOVEit server somewhere. Exposure was not bounded by your own asset inventory, and for many victims the first they knew of it was a notification from a supplier.

Part 4: managed file transfer as an asset class

The reason Cl0p returned to this well four times is structural, and naming the structure is the most transferable part of the case:

- **It is internet-facing by design.** A file-transfer product has to accept connections from outside to do its job, so it is always on the edge, always reachable, and always a first-rank target.
- **It concentrates other people's most sensitive data.** Payroll, health, financial and benefits data funnel through these systems precisely because they are the secure channel, which makes one server a dense target.
- **It is often owned as plumbing.** These products are frequently bought and run by lines of business or operations teams, patched on a slow cadence, and under-monitored, because they are seen as infrastructure rather than as a crown-jewel application.
- **Its blast radius is other organizations.** Because so many of these deployments are run by service providers, a single compromise cascades to that provider's customers, which is fourth-party risk made concrete.

Put together, those four properties make managed file transfer a category that deserves standing, elevated treatment in a vulnerability management program: a named asset class with its own inventory, its own shortest-clock patch SLA, its own monitoring, and its own place in third-party risk reviews. See the Supply Chain Security Reference and the Edge Device Security Reference.

Cross-cutting themes

- **Data-theft extortion is a ransomware-grade event without ransomware.** No encryption occurred in MOVEit, yet the business impact (breach notification, regulatory exposure, extortion pressure, reputational harm) matched a ransomware incident. A prioritization model that weights encryption behavior over data exposure misreads this class of attack. See the Ransomware Defense Reference.

- **Managed file transfer is a crown-jewel attack surface, not plumbing.** These products are internet-facing, aggregate many parties' sensitive data, and are often operated outside the security team's close attention. That combination is why the same actor hit the same product class four times.
- **Zero-day exploitation defeats patch cadence by definition.** MOVEit and Cleo were exploited before a patch existed. Defense of this asset class therefore cannot rest on patching alone; it needs exposure reduction, egress control, web-shell detection and a rehearsed take-offline option. This mirrors the edge-device lesson in the SharePoint ToolShell case study.
- **Your exposure includes your vendors' assets.** Much of the MOVEit harm reached organizations that never ran MOVEit. Fourth-party risk is real risk, and mapping which vendors hold your data in which transfer systems is part of vulnerability management, not a separate compliance exercise. See the Supply Chain Security Reference.
- **Minimize the data at rest.** The single control that would have most reduced the harm is one that is easy to overlook: not leaving months or years of transferred files sitting on an internet-facing transfer server. Data that is delivered and promptly removed cannot be stolen in bulk from the staging point.

Sources

- Progress Software advisories for CVE-2023-34362, CVE-2023-35036 and CVE-2023-35708, and the MOVEit Transfer security notifications.
- The joint CISA and FBI advisory AA23-158A on Cl0p ransomware exploitation of MOVEit Transfer, and the CISA Known Exploited Vulnerabilities catalog entries for the MOVEit, GoAnywhere and Cleo flaws.
- Fortra advisory for CVE-2023-0669 (GoAnywhere MFT), Cleo advisories for CVE-2024-50623 and CVE-2024-55956 with Rapid7's analysis distinguishing the two, and reporting on the Accellion FTA chain (CVE-2021-27101 and related) and the DEWMODE web shell.
- Microsoft Threat Intelligence attribution of the MOVEit exploitation to Lace Tempest (Cl0p), and reporting from Mandiant and Huntress on the LEMURLOOT web shell.
- Emsisoft's running MOVEit impact tally (about 2,773 organizations and about 95.8 million individuals as of August 2024) and corroborating reporting from BleepingComputer, The Record and security trackers; figures are reported totals and best treated as a floor.

Related references

- Edge Device Security Reference
- Supply Chain Security Reference
- Ransomware Defense Reference
- Vulnerability Prioritization Reference
- The SharePoint ToolShell Mass Exploitation
- Notable Incidents, Vulnerability Management Reference